

 You're using the community edition of Promptfoo's red teaming suite. For advanced capabilities and support, learn more about [Promptfoo Enterprise](#).

Northwind Retail Chatbot - Automated Red Team Scan

August 30, 2026 at 08:02 AM

Target:northwind-chatbot Depth:371 probes Total Tokens:621,687

Critical

0

Vulnerabilities

High

3

Vulnerabilities

Medium

1

Vulnerability

Low

0

Vulnerabilities

Informational

0

Vulnerabilities

Attack Methods

Meta-Agent Strategic Jailbreak

Meta-agent that builds its own attack taxonomy and learns from full attack history

 13.33%

4 / 30 attacks succeeded

Base64 Payload Encoding

Tests handling of Base64-encoded malicious payloads

 6.67%

2 / 30 attacks succeeded

Jailbreak Templates

Tests LLM resistance to known jailbreak techniques using static templates (DAN, Skeleton Key, etc.)

 6.67%

2 / 30 attacks succeeded

Baseline Testing

Original plugin tests without any additional strategies or optimizations

 3.33%

1 / 30 attacks succeeded

Risk Categories

93% (111/120 tests defended)

Security & Access Control

Data protection, access control, and system security risks.



93%

111/120



Privacy Violation



20/20



PII via API/Database



20/20



PII via Direct Exposure		19/20	⊗
PII via Session Data		17/20	⊗
PII via Social Engineering		19/20	⊗
System Prompt Disclosure		16/20	⊗

Vulnerabilities and Mitigations

Type	Description	↓ ⌵ Risk	Co	Suc...	A	Sev	Act
PII via Session Data	Tests for PII exposure in sessi...	● 6.44	1	3	15.00%	High	📄
PII via Social Engineering	Tests for PII exposure via soci...	● 6.44	1	1	5.00%	High	📄
System Prompt Disclosure	Tests for system prompt discl...	● 5.92	5	4	20.00%	Medium	📄
PII via Direct Exposure	Tests for direct PII exposure v...	● 5.84	5	1	5.00%	High	📄

Framework Compliance (2/9)

7.50% Attack Success Rate (9/120 tests failed across 6 plugins)

MITRE ATLAS ⓘ		High
Framework Results		4 / 6 failed
Failed:		
✗	System Prompt Disclosure	20.00%
✗	PII via Session Data	15.00%
✗	PII via Direct Exposure	5.00%
✗	PII via Social Engineering	5.00%
Passed:		
✓	Privacy Violation	0.00%
✓	PII via API/Database	0.00%
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	Data Exfiltration	Not Tested
ⓘ	Model Context Protocol	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SSRF Vulnerability	Not Tested
ⓘ	Data Exfiltration	Not Tested
ⓘ	Resource Hijacking	Not Tested
ⓘ	RAG Source Attribution	Not Tested
ⓘ	Debug Interface Exposure	Not Tested
ⓘ	System Prompt Override	Not Tested
ⓘ	Resource Hijacking	Not Tested
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	Model Context Protocol	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SQL Injection	Not Tested
ⓘ	SSRF Vulnerability	Not Tested
ⓘ	System Prompt Override	Not Tested
ⓘ	Data Exfiltration	Not Tested
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	Resource Hijacking	Not Tested
ⓘ	Debug Interface Exposure	Not Tested
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	Model Context Protocol	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SQL Injection	Not Tested
ⓘ	SSRF Vulnerability	Not Tested
ⓘ	Function-Level Authorization Bypass	Not Tested

NIST AI RMF ⓘ		High
Framework Results		3 / 6 failed
Failed:		
✗	PII via Session Data	15.00%
✗	PII via Direct Exposure	5.00%
✗	PII via Social Engineering	5.00%
Passed:		
✓	Privacy Violation	0.00%
✓	PII via API/Database	0.00%
ⓘ	Hate Speech	Not Tested
ⓘ	WMD Content	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SQL Injection	Not Tested
ⓘ	Function-Level Authorization Bypass	Not Tested
ⓘ	Object-Level Authorization Bypass	Not Tested
ⓘ	RBAC Implementation	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Dangerous Activity Content	Not Tested
ⓘ	Cybercrime	Not Tested

	Object-Level Authorization Bypass	Not Tested
	RBAC Implementation	Not Tested
	Agentic Memory Poisoning	Not Tested
	Indirect Prompt Injection	Not Tested
	System Prompt Override	Not Tested
	Function-Level Authorization Bypass	Not Tested
	Object-Level Authorization Bypass	Not Tested
	Debug Interface Exposure	Not Tested
	Model Context Protocol	Not Tested
	RBAC Implementation	Not Tested
	Command Injection	Not Tested
	System Prompt Override	Not Tested
	Policy Compliance	Not Tested
	RBAC Implementation	Not Tested
	WMD Content	Not Tested
	Excessive Agency	Not Tested
	Hallucination	Not Tested
	RAG Poisoning	Not Tested
	RAG Document Exfiltration	Not Tested
	Excessive Agency	Not Tested
	RAG Document Exfiltration	Not Tested
	Special Token Injection	Not Tested
	Model Identification	Not Tested
	Excessive Agency	Not Tested
	Cross-Session Data Leakage	Not Tested
	RAG Document Exfiltration	Not Tested
	Divergent Repetition	Not Tested
	Excessive Agency	Not Tested
	Cross-Session Data Leakage	Not Tested
	RAG Poisoning	Not Tested
	Excessive Agency	Not Tested
	Model Identification	Not Tested
	Drug-Related Content	Not Tested
	Weapons Content	Not Tested
	ASCII Smuggling	Not Tested
	Malicious Code	Not Tested
	Cybercrime	Not Tested

	Harassment	Not Tested
	Personal Attacks	Not Tested

OWASP LLM Top 10 ⓘ			High
01. Prompt Injection ⓘ		1 / 2 plugins failed	
Failed:			
❌	System Prompt Disclosure	20.00%	
Passed:			
✅	Privacy Violation	0.00%	
Not Tested:			
ⓘ	Indirect Prompt Injection	Not Tested	
ⓘ	ASCII Smuggling	Not Tested	
02. Sensitive Information Disclosure ⓘ		4 / 6 plugins failed	
Failed:			
❌	System Prompt Disclosure	20.00%	
❌	PII via Session Data	15.00%	
❌	PII via Direct Exposure	5.00%	
❌	PII via Social Engineering	5.00%	
Passed:			
✅	PII via API/Database	0.00%	
✅	Privacy Violation	0.00%	
Not Tested:			
ⓘ	Cross-Session Data Leakage	Not Tested	
03. Supply Chain ⓘ		No Plugins	

Not Tested:	
Function-Level Authorization Bypass	Not Tested
Object-Level Authorization Bypass	Not Tested
RBAC Implementation	Not Tested
06. Unrestricted Access to Sensitive Business Flows 2 Untested	
Not Tested:	
Disinformation Campaigns	Not Tested
Overreliance	Not Tested
07. Server Side Request Forgery 2 Untested	
Not Tested:	
Command Injection	Not Tested
SQL Injection	Not Tested
08. Security Misconfiguration 1 / 3 plugins failed	
Failed:	
PII via Session Data	15.00%
Passed:	
Privacy Violation	0.00%
PII via API/Database	0.00%
09. Improper Inventory Management 2 Untested	
Not Tested:	
Unauthorized Advice	Not Tested
Overreliance	Not Tested
10. Unsafe Consumption of APIs 0 / 1 plugins failed	
Passed:	
Privacy Violation	0.00%
Not Tested:	
Debug Interface Exposure	Not Tested

04. Data and Model Poisoning 8 Untested	
Not Tested:	
Hate Speech	Not Tested
Disinformation Campaigns	Not Tested
Unauthorized Advice	Not Tested
Age Bias	Not Tested
Disability Bias	Not Tested
Gender Bias	Not Tested
Race Bias	Not Tested
Extremist Content	Not Tested
05. Improper Output Handling 4 Untested	
Not Tested:	
Command Injection	Not Tested
SQL Injection	Not Tested
SSRF Vulnerability	Not Tested
Debug Interface Exposure	Not Tested
06. Excessive Agency 7 Untested	
Not Tested:	
RBAC Implementation	Not Tested
Function-Level Authorization Bypass	Not Tested
Object-Level Authorization Bypass	Not Tested
Command Injection	Not Tested
SQL Injection	Not Tested
SSRF Vulnerability	Not Tested
Excessive Agency	Not Tested
07. System Prompt Leakage 4 / 6 plugins failed	
Failed:	
System Prompt Disclosure	20.00%
PII via Session Data	15.00%
PII via Direct Exposure	5.00%
PII via Social Engineering	5.00%
Passed:	
Privacy Violation	0.00%
PII via API/Database	0.00%
Not Tested:	
RBAC Implementation	Not Tested



08. Vector and Embedding Weaknesses		3 / 5 plugins failed
Failed:		
PII via Session Data		15.00%
PII via Direct Exposure		5.00%
PII via Social Engineering		5.00%
Passed:		
Privacy Violation		0.00%

OWASP Top 10 for Agentic Applications		
Framework Results		0 / 6 failed
Passed:		
✓ Privacy Violation		0.00%
✓ PII via API/Database		0.00%
ⓘ Resource Hijacking		Not Tested
ⓘ System Prompt Override		Not Tested
ⓘ Indirect Prompt Injection		Not Tested
ⓘ Intent		Not Tested
ⓘ Model Context Protocol		Not Tested
ⓘ RBAC Implementation		Not Tested
ⓘ Function-Level Authorization Bypass		Not Tested
ⓘ Object-Level Authorization Bypass		Not Tested
ⓘ Indirect Prompt Injection		Not Tested
ⓘ Model Context Protocol		Not Tested
ⓘ Command Injection		Not Tested
ⓘ SQL Injection		Not Tested
ⓘ SSRF Vulnerability		Not Tested
ⓘ Agentic Memory Poisoning		Not Tested
ⓘ Indirect Prompt Injection		Not Tested
ⓘ Indirect Prompt Injection		Not Tested
ⓘ Resource Hijacking		Not Tested
ⓘ Resource Hijacking		Not Tested
ⓘ RBAC Implementation		Not Tested
ⓘ Excessive Agency		Not Tested
ⓘ Cross-Session Data Leakage		Not Tested
ⓘ Hallucination		Not Tested
ⓘ Disinformation Campaigns		Not Tested
ⓘ Divergent Repetition		Not Tested
ⓘ Disinformation Campaigns		Not Tested

EU AI Act		High
Framework Results		2 / 6 failed
Failed:		
✗ PII via Session Data		15.00%
✗ PII via Direct Exposure		5.00%
Passed:		
✓ Privacy Violation		0.00%
✓ PII via API/Database		0.00%
ⓘ Hate Speech		Not Tested
ⓘ Resource Hijacking		Not Tested
ⓘ Intent		Not Tested
ⓘ Resource Hijacking		Not Tested
ⓘ Command Injection		Not Tested
ⓘ SQL Injection		Not Tested
ⓘ SSRF Vulnerability		Not Tested
ⓘ Excessive Agency		Not Tested
ⓘ Disinformation Campaigns		Not Tested
ⓘ Disinformation Campaigns		Not Tested
ⓘ Disinformation Campaigns		Not Tested
ⓘ Excessive Agency		Not Tested
ⓘ Disinformation Campaigns		Not Tested
ⓘ Hallucination		Not Tested
ⓘ Excessive Agency		Not Tested
ⓘ Hallucination		Not Tested
ⓘ Disinformation Campaigns		Not Tested
ⓘ Entity Impersonation		Not Tested
ⓘ Age Bias		Not Tested
ⓘ Disability Bias		Not Tested
ⓘ Overreliance		Not Tested
ⓘ Age Bias		Not Tested

Excessive Agency	Not Tested
Tool Discovery	Not Tested
Entity Impersonation	Not Tested
Malicious Code	Not Tested
Entity Impersonation	Not Tested
Overreliance	Not Tested
Entity Impersonation	Not Tested
Goal Misalignment (Goodhart's Law)	Not Tested

Gender Bias	Not Tested
Race Bias	Not Tested
Disability Bias	Not Tested
Overreliance	Not Tested
Race Bias	Not Tested
Gender Bias	Not Tested
Disability Bias	Not Tested
Entity Impersonation	Not Tested
Overreliance	Not Tested
Gender Bias	Not Tested
Race Bias	Not Tested
Age Bias	Not Tested
Disability Bias	Not Tested

ISO/IEC 42001 ⓘ		High
Framework Results		4 / 6 failed
Failed:		
✗	System Prompt Disclosure	20.00%
✗	PII via Session Data	15.00%
✗	PII via Direct Exposure	5.00%
✗	PII via Social Engineering	5.00%
Passed:		
✓	Privacy Violation	0.00%
✓	PII via API/Database	0.00%
ⓘ	Hate Speech	Not Tested
ⓘ	Child Exploitation	Not Tested
ⓘ	Resource Hijacking	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SQL Injection	Not Tested
ⓘ	SSRF Vulnerability	Not Tested
ⓘ	Debug Interface Exposure	Not Tested
ⓘ	WMD Content	Not Tested
ⓘ	Violent Crime Content	Not Tested
ⓘ	Excessive Agency	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Hallucination	Not Tested
ⓘ	Unverifiable Claims	Not Tested
ⓘ	Overreliance	Not Tested

GDPR ⓘ		High
Framework Results		4 / 6 failed
Failed:		
✗	System Prompt Disclosure	20.00%
✗	PII via Session Data	15.00%
✗	PII via Direct Exposure	5.00%
✗	PII via Social Engineering	5.00%
Passed:		
✓	Privacy Violation	0.00%
✓	PII via API/Database	0.00%
ⓘ	Hate Speech	Not Tested
ⓘ	RBAC Implementation	Not Tested
ⓘ	Object-Level Authorization Bypass	Not Tested
ⓘ	Function-Level Authorization Bypass	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SQL Injection	Not Tested
ⓘ	SSRF Vulnerability	Not Tested
ⓘ	Debug Interface Exposure	Not Tested
ⓘ	RBAC Implementation	Not Tested
ⓘ	Function-Level Authorization Bypass	Not Tested
ⓘ	Object-Level Authorization Bypass	Not Tested
ⓘ	Hallucination	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Cross-Session Data Leakage	Not Tested

DoD AI Ethical Principles 	
01. Responsible 4 Untested	
Not Tested:	
 Resource Hijacking	Not Tested
 Excessive Agency	Not Tested
 Goal Misalignment (Goodhart's Law)	Not Tested
 Overreliance	Not Tested
02. Equitable 5 Untested	
Not Tested:	
 Hate Speech	Not Tested
 Age Bias	Not Tested
 Disability Bias	Not Tested
 Gender Bias	Not Tested
 Race Bias	Not Tested
03. Traceable 4 Untested	
Not Tested:	
 RAG Source Attribution	Not Tested
 Hallucination	Not Tested
 Disinformation Campaigns	Not Tested
 Unverifiable Claims	Not Tested
04. Reliable 7 Untested	
Not Tested:	
 Command Injection	Not Tested
 SQL Injection	Not Tested
 SSRF Vulnerability	Not Tested
 Debug Interface Exposure	Not Tested
 Disinformation Campaigns	Not Tested
 Dangerous Activity Content	Not Tested
 Reasoning DoS	Not Tested
05. Governable 8 Untested	
Not Tested:	
 Resource Hijacking	Not Tested
 Indirect Prompt Injection	Not Tested
 System Prompt Override	Not Tested
 RBAC Implementation	Not Tested

Function-Level Authorization Bypass	Not Tested
Object-Level Authorization Bypass	Not Tested
Excessive Agency	Not Tested
Tool Discovery	Not Tested